

ISEC 2076: Security Mechanisms

Nessus Vulnerability Scan

Assignment #2

Matthew Boutilier
Fall 2025

Table of Contents

Table of Contents	1
Overview.....	2
Targets.....	2
Quick Reference – Legend.....	2
Unauthenticated Scan	3
Target: 172.16.139.164	3
Target: 172.16.138.115	5
Target: 172.16.137.148	6
Credentialed Scan	7
Target: 172.16.139.3	7
Target: 172.16.139.179	10
Target: 172.16.138.66	11
References.....	12

Overview

This comprehensive security assessment evaluated specified target devices using both uncredentialed and credentialed scanning techniques. The results confirm that several exploitable weaknesses exist across the analyzed assets. The Uncredentialed Scan identified various external exposure points that could be exploited by an attacker with no prior access, highlighting critical perimeter security gaps on the scanned systems. The second phase of the assessment, the Credentialed Scan, uncovered numerous internal system flaws on individual devices, primarily focusing on missing patches and improper configurations, which introduce significant risk once an attacker gains a foothold. This report translates these technical findings into clear, non-technical risk summaries, detailing both the publicly visible weaknesses and the severe internal flaws require immediate action to safeguard the organization's assets and maintain/improve the current security posture.

Targets

Target IP	User	Scan Type	Scan Date	OS	Duration
172.16.139.164	Matt	Uncredentialed	2025-09-24	Windows 11	00h 17m
172.16.138.115	Ben	Uncredentialed	2025-09-24	NetApp 9.3	00h 09m
172.16.137.148	Alex	Uncredentialed	2025-09-24	NetApp 9.3	00h 09m
172.16.139.3	Matt	Credentialed	2025-10-01	Windows 11 Pro	00h 48m
172.16.138.66	Alex	Credentialed	2025-10-01	Windows 10 Edu.	00h 30m
172.16.139.179	Ben	Credentialed	2025-10-01	Windows 10 Edu.	00h 27m

Note: IP addresses changed between Uncredentialed and Credentialed scans, user column added to indicate the same physical device.
Table 1: Table of identifying information about scan target(s).

Quick Reference – Legend

Critical

High

Medium

Low

Info

Note: If there are multiple severities for a given vulnerability, it will be colour coded based on the highest severity.

Uncredentialed Scan

Target: 172.16.139.164

Severity	Vulnerability	Description	Mitigation
Medium	Echo Service Detection	Port(s): 7 The Echo Service repeats any data sent to it, which can be abused for DoS attacks. This service is now outdated. [1]	Modify Registry Keys: • EnableTcpEcho Value: 0 • EnableUdpEcho Value: 0
Medium	Quote of the Day (QOTD) Service Detection	Port(s): 17 Can be susceptible to a 'pingpong' attack, a type of DoS attack, which is a result of two or more machines repeatedly sending QOTD messages back and forth. [2]	Modify Registry Keys: • EnableTcpQotd Value: 0 • EnableUdpQotd Value: 0
Medium / Info	SSL Certificate Cannot Be Trusted	Port(s): 8834 The certificate is untrustworthy due to a broken chain of trust, caused by an unrecognized authority, date error, or bad signature. This increases the chance of a MITM attack. [3]	Purchase or generate a proper SSL certificate for this service.
Info	HTTP Server Type and Version	Port(s): 9031, 50128 A web server is running. [4]	N/A
Info	Microsoft Windows SMB Service Detection	Port(s): 139, 445 Server Message Block traffic is being accepted by the target machine. [5]	N/A

Table 2: Uncredentialed scan results of target 172.16.139.164

Severity	Vulnerability	Description	Mitigation
Info	SSL / TLS Versions Supported	Port(s): 8834, 27036 The target machine has encrypted communication enabled. [6]	N/A

Table 3: Continued Table – Uncredentialed scan results of target 172.16.139.164

Target: 172.16.138.115

Severity	Vulnerability	Description	Mitigation
Info	SSL Cipher Block Chaining Cipher Suites Supported	Port(s): 27036 The target machine supports the use of SSL ciphers that operate in Cipher Block Chaining mode. These ciphers have additional security, however if used improperly can cause data leaks. [7]	N/A
Info	SSL / TLS Versions Supported	Port(s): 27036 The target machine has encrypted communication enabled. [6]	N/A
Info	Nessus SYN scanner	Port(s): 7680, 27036 Tenable Nessus SYN scanner detected on target device. SYN scans are less intrusive than standard TCP scans. [8]	N/A

Table 4: Uncredentialed scan results of target 172.16.138.115

Target: 172.16.137.148

Severity	Vulnerability	Description	Mitigation
Info	Common Platform Enumeration (CPE)	Port(s): N/A The target machine provided a list of hardware and software information. [9]	N/A
Info	Device Type	Port(s): N/A The target machine provided Operating System information. [10]	N/A
Info	Ethernet Card Manufacturer Detection	Port(s): N/A The target machine's Ethernet Card Manufacturer was identified via MAC address/Organizationally Unique Identifier registered with IEEE. [11] [12]	N/A

Table 5: Uncredentialed scan results of target 172.16.137.148

Credentialed Scan

Target: 172.16.139.3

Severity	Vulnerability	Description	Mitigation
Critical / High / Medium	VMware Workstation 17.x < 17.6.3 Multiple Vulnerabilities (VMSA-2024-0004)	Port(s): 445 The target machine is running a vulnerable version of VMware Workstation, which has multiple flaws, a TOCTOU vulnerability allowing a malicious actor to execute code on the host, and an out-of-bounds read that can leak memory from the VMX process. [13] [14]	Update to VMware Workstation version 17.6.3 or later.
	High Microsoft Windows Subsystem for Linux (WSL2) < 2.5.10 Kernel Elevation of Privilege	Port(s): N/A The version of WSL2 on the target machine has a kernel elevation of privilege vulnerability. A TOCTOU vulnerability would allow an attacker to elevate their privileges on the local machine. [15] [16] [17]	Upgrade to Microsoft Windows Subsystem for Linux (WSL2) version 2.5.10 or later via the Microsoft Store.

Table 6: Credentialed scan results of target 172.16.139.3

Severity	Vulnerability	Description	Mitigation
High	Microsoft Windows Update Reboot Required	Port(s): N/A Based on information from the target machines registry, the machine is missing new security updates from Microsoft, this may lead to multiple additional vulnerabilities. [18] [19]	Reboot the remote system to put pending changes into effect.
Medium	Echo Service Detection	Port(s): 7 The Echo Service repeats any data sent to it, which can be abused for DoS attacks. This service is now outdated. [1]	Modify Registry Keys: • EnableTcpEcho Value: 0 • EnableUdpEcho Value: 0
Medium	Quote of the Day (QOTD) Service Detection	Port(s): 17 Can be susceptible to a 'pingpong' attack, a type of DoS attack, which is a result of two or more machines repeatedly sending QOTD messages back and forth. [2]	Modify Registry Keys: • EnableTcpQotd Value: 0 • EnableUdpQotd Value: 0
Medium	WinVerify-Trust Signature Validation (EnableCertPadding-Check)	Port(s): 445 Target machine has missing or misconfigured registry keys. This can lead to remote code execution-based attacks. [20] [21]	Modify Registry Keys: • EnableCertPaddingCheck Value: 1

Table 7: Continued Table – Credentialed scan results of target 172.16.139.3

Severity	Vulnerability	Description	Mitigation
Medium	SSL Certificate Cannot Be Trusted	Port(s): 8834 The certificate is untrustworthy due to a broken chain of trust, caused by an unrecognized authority, date error, or bad signature. This increases the chance of a MITM attack. [3]	Purchase or generate a proper SSL certificate for this service.

Table 8: Continued Table – Credentialed scan results of target 172.16.139.3

Target: 172.16.139.179

Severity	Vulnerability	Description	Mitigation
Medium	WinVerify-Trust Signature Validation (EnableCertPadding-Check)	Port(s): 445 Target machine has missing or misconfigured registry keys. This can lead to remote code execution-based attacks. [20] [21]	Modify Registry Keys: • EnableCertPaddingCheck Value: 1
Info	Microsoft Windows SMB Last Logged On User Disclosure	Port(s): 445 The target machine provided username of last successful logon from automatic logon configuration. [22] [23]	N/A: Retrieved using valid Credentials.
Info	Microsoft Windows 'Administrators' Group User List	Port(s): 445 The target machine provided the member list for the "Administrators" user group. [24]	N/A: Retrieved using valid Credentials.

Table 9: Credentialed scan results of target 172.16.139.179

Target: 172.16.138.66

Severity	Vulnerability	Description	Mitigation
High	VMware Workstation 13.0.x < 13.6.4 / 17.0.x < 17.6.4 Multiple Vulnerabilities (VMSA-2025-0013)	Port(s): 445 The target machine is running a vulnerable version of VMware Workstation, which has multiple flaws, a TOCTOU vulnerability allowing a malicious actor to execute code on the host, and an out-of-bounds read that can leak memory from the VMX process. [13] [14]	Update to VMware Workstation version 13.6.4, 17.6.4, or later.
Medium	WinVerify-Trust Signature Validation (EnableCertPadding-Check)	Port(s): 445 Target machine has missing or misconfigured registry keys. This can lead to remote code execution-based attacks. [20] [21]	Modify Registry Keys: • EnableCertPaddingCheck Value: 1
Info	BIOS Info (SMB)	Port(s): N/A The target machine provided information about the system BIOS via SMB. [25]	

Table 10: Credentialed scan results of target 172.16.138.66

References

- [1] Tenable Nessus, "Echo Service Detection," Tenable Inc., 12 June 2020. [Online]. Available: <https://www.tenable.com/plugins/nessus/10061>. [Accessed October 2025].
- [2] Tenable Nessus, "Quote of the Day (QOTD) Service Detection," Tenable Inc., 04 October 2019. [Online]. Available: <https://www.tenable.com/plugins/nessus/10198>. [Accessed October 2025].
- [3] Tenable Nessus, "SSL Certificate Cannot Be Trusted," Tenable Inc., 16 June 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/51192>. [Accessed October 2025].
- [4] Tenable Nessus, "HTTP Server Type and Version," Tenable Inc., 30 October 2020. [Online]. Available: <https://www.tenable.com/plugins/nessus/10107>. [Accessed October 2025].
- [5] Tenable Nessus, "Microsoft Windows SMB Service Detection," Tenable Inc., 11 February 2021. [Online]. Available: <https://www.tenable.com/plugins/nessus/11011>. [Accessed October 2025].
- [6] Tenable Nessus, "SSL / TLS Versions Supported," Tenable Inc., 16 June 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/56984>. [Accessed October 2025].
- [7] Tenable Nessus, "SSL Cipher Block Chaining Cipher Suites Supported," Tenable Inc., 03 February 2021. [Online]. Available: <https://www.tenable.com/plugins/nessus/70544>. [Accessed October 2025].
- [8] Tenable Nessus, "Nessus SYN Scanner," Tenable Inc., 14 July 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/11219>. [Accessed October 2025].
- [9] Tenable Nessus, "Common Platform Enumeration (CPE)," Tenable Inc., 21 September 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/45590>. [Accessed October 2025].

- [10] Tenable Nessus, "Device Type," Tenable Inc., 12 March 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/54615>. [Accessed October 2025].
- [11] Tenable Nessus, "Ethernet Card Manufacturer Detection," Tenable Inc., 13 May 2020. [Online]. Available: <https://www.tenable.com/plugins/nessus/35716>. [Accessed October 2025].
- [12] IEEE Standards Association, "IEEE Registration Authority FAQs," Institute of Electrical and Electronics Engineers, [Online]. Available: <https://standards.ieee.org/faqs/regauth/>. [Accessed October 2025].
- [13] Tenable Nessus, "VMware Workstation 17.x < 17.6.3 Multiple Vulnerabilities (VMSA-2024-0004)," Tenable Inc., 27 May 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/222493>. [Accessed October 2025].
- [14] Broadcom Support, "VMSA-2025-0004: VMware ESXi, Workstation, and Fusion updates address multiple vulnerabilities (CVE-2025-22224, CVE-2025-22225, CVE-2025-22226)," Broadcom Inc., 04 March 2025. [Online]. Available: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/25390>. [Accessed October 2025].
- [15] Tenable Nessus, "Microsoft Windows Subsystem for Linux (WSL2) < 2.5.10 Kernel Elevation of Privilege (August 2025)," Tenable Inc., 15 August 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/250272>. [Accessed October 2025].
- [16] Microsoft Security Response Center, "Windows Subsystem for Linux (WSL2) Kernel Elevation of Privilege Vulnerability," Microsoft, 12 August 2025. [Online]. Available: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-53788>. [Accessed October 2025].
- [17] CVE.org, "CVE-2025-53788," Mitre Corporation, 12 August 2025. [Online]. Available: <https://www.cve.org/CVERecord?id=CVE-2025-53788>. [Accessed October 2025].

- [18] Tenable Nessus, "Microsoft Windows Update Reboot Required," Tenable Inc., 19 April 2024. [Online]. Available: <https://www.tenable.com/plugins/nessus/35453>. [Accessed October 2025].
- [19] Microsoft Learn, "PendingFileRenameOperations," Microsoft, 03 March 2010. [Online]. Available: [https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-2000-server/cc960241\(v=technet.10\)?redirectedfrom=MSDN](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-2000-server/cc960241(v=technet.10)?redirectedfrom=MSDN). [Accessed October 2025].
- [20] Tenable Nessus, "WinVerifyTrust Signature Validation CVE-2013-3900 Mitigation (EnableCertPaddingCheck)," Tenable Inc., 06 January 2025. [Online]. Available: <https://www.tenable.com/plugins/nessus/166555>. [Accessed October 2025].
- [21] Microsoft Security Response Center, "WinVerifyTrust Signature Validation Vulnerability," <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2013-3900>, Microsoft, 23 December 2024. [Online]. Available: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2013-3900>. [Accessed October 2025].
- [22] Tenable Nessus, "Microsoft Windows SMB Last Logged On User Disclosure," Tenable Inc., 02 September 2019. [Online]. Available: <https://www.tenable.com/plugins/nessus/38689>. [Accessed October 2025].
- [23] Microsoft Learn, "Turn on automatic logon in Windows," Microsoft, 15 January 2025. [Online]. Available: <https://learn.microsoft.com/en-us/troubleshoot/windows-server/user-profiles-and-logon/turn-on-automatic-logon>. [Accessed October 2025].
- [24] Tenable Nessus, "Microsoft Windows 'Administrators' Group User List," Tenable Inc., 16 May 2018. [Online]. Available: <https://www.tenable.com/plugins/nessus/10902>. [Accessed October 2025].
- [25] Tenable Nessus, "BIOS Info (SMB)," Tenable Inc., 11 June 2024. [Online]. Available: <https://www.tenable.com/plugins/nessus/34097>. [Accessed October 2025].